Examining Golden & Silver Tickets in Kerberos

Edward Ettesvoll

Spring 2024

Research question: What methods exist for detecting and preventing Golden and Silver Ticket attacks within Kerberos environments, and how do they differ?

Initial note: See the next-to-last section of this paper for a briefing on specific terminology and abbreviations adopted herein. This is meant to clarify the use of terms that typically vary greatly in different research on the topic in question.

1 Introduction

Today, a substantial number of networks – especially large-scale ones – utilize the Kerberos protocol for authentication. Millions of organizations globally rely on this protocol through their use of services such as Active Directory, where Kerberos is the de facto authentication standard. Notably, it is not only used in Windows services, but also in Unix-like systems. Because of this widespread adoption, many methods have been developed to exploit weaknesses in the protocol, including reflection and replay attacks. More recently, two novel methods have surfaced, involving the use of so-called *Golden Tickets* and *Silver Tickets*. As the names suggest, these two attacks are rooted in Kerberos' use of *tickets* for authenticating users in a network. Research shows that they possess two particularly worrisome traits from a network security perspective:

1) They facilitate lateral movement by an attacker.
2) They allow an attacker to stay hidden in the network.

When combining these two factors, the damage potential is vast, creating a great need for exploring and discovering ways in which the attacks in question ultimately can be detected and prevented. However, Golden and Silver tickets make prevention and detection an especially complicated matter, since they are usually obtained by an attacker in possession of valid credentials. Because the attacker is effectively using legitimate credentials in their infiltration and movement through the network, traditional detection mechanisms that rely on identifying invalid logins or unauthorized access may not be triggered. A critical concern arises: If deviation from normal user behavior is minimal in these type of attacks, how do we successfully and effectively mitigate them?

In the quest to answer this question, most existing research highlights the importance of maintaining extensive log monitoring of security events, to have a fair chance of detecting the use of forged tickets. Because the two attacks are employed during the post-exploitation phase, many researchers also tend to emphasize how crucial it is to implement robust security at earlier stages – that is, before infiltration takes place, so there is no way for the attacker to utilize Golden or Silver tickets in the first place. However, the ways into a network are nearly endless, illustrating the importance of not only establishing indirect, but also direct approaches for dealing with these forged ticket attacks.

Moreover, nearly all existing literature on Golden and Silver tickets revolve around Microsoft-centric environments. For this reason, information is often presented in a manner that lines up well with the designs and workings of these particular environments, but not necessarily of others. A simple example is the widespread replacement of the Key Distribution Center (KDC) with the Domain Controller (DC) in figures and illustrations – in Active Directory, the former is often integrated into the latter. In addition, most relevant research material has a tendency to delve deep into exclusive configuration and functionality native to precisely Active Directory. To some extent, this is all understandable; these attacks were, after all, originally described in an Active Directory context.

Ultimately though, Golden and Silver tickets are theoretically viable in all kinds of environments and systems (e.g. Unix/Linux) that utilize the Kerberos authentication procedure. Therefore, this paper intentionally deviates from existing literature in that it seeks to maintain as pure of a Kerberos context as possible. The purpose is not to present a detailed picture of how Golden and Silver ticket attacks affect solely Windows-based environments; rather, this review aims at providing a general understanding of why these attacks work in Kerberos, how they can be detected and mitigated (sometimes involving more practical and precise suggestions, such as logging mechanisms in Windows), and in what ways they differ. This latter point is especially important, since proper comparisons between the two attacks are hard to come by in existing literature. In general, absence of a broadened focus and attack type comparison represent the most notable current research gaps that this paper attempts to fill.

2 Background

While the Kerberos protocol has existed for well over one third of a century, Golden Ticket and Silver Ticket attacks are relatively new concepts. They were initially discussed at a series of public and private talks, taking place at various Black Hat and Blue Hat security conferences in 2014.[1] At these talks, French security researcher Benjamin Delpy introduced the two attacks as features in his self-developed tool named Mimikatz[2], which allows users to view and save authentication credentials such as Kerberos tickets. Since its inception, the tool

[1] https://www.qomplx.com/blog/qomplx-knowledge-silver-ticket-attacks-explained/
[2] https://www.qomplx.com/blog/qomplx-knowledge-golden-ticket-attacks-explained/

has been widely used in the cyberspace, primarily for testing and demonstrating security weaknesses in Windows environments. Today, it is included in security-oriented operating systems such as Kali Linux.

To understand how Golden Ticket and Silver Ticket attacks work and how they can be detected, fundamental knowledge of the Kerberos protocol is required.

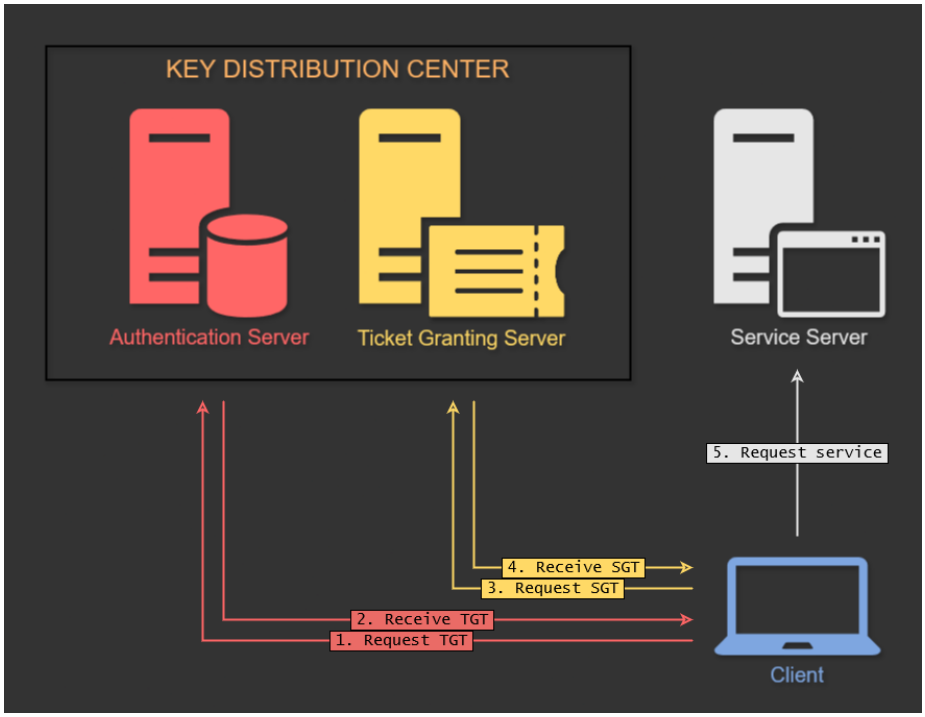


Figure 1: Standard procedure of the Kerberos protocol in a single(?) realm

Figure 1 illustrates the standard steps of the Kerberos protocol. When a client wants to access a specific application or service in a domain, it must first 1) authenticate itself with the domain's Authentication Server (AS). If the client is successfully authenticated, it will 2) receive a Ticket Granting Ticket (TGT), which – as the term suggests – is essentially a ticket that gives the right to another ticket. The client then 3) presents the TGT to the domain's Ticket Granting Server (TGS), and will in turn 4) receive a Service Granting Ticket (SGT), also called a service ticket. Finally, the client 5) presents the SGT to the Service Server (SS) it is intended for and gets access to the desired service.

The fundamental difference between a TGT and SGT can be illustrated with a metaphor: The former gives access to the theatre complex, while the latter gives access to a specific show in a specific theatre at a specific time. Once a ticket for a specific show is obtained, this ticket will not allow the entrance into any

other show, because we have only been authorized to see the specified show.[3]

It is essential to note that Golden Tickets and Silver Tickets, like most other ticket forging attacks, are typically used during the post-exploitation phase to establish domain persistence. This implies that for a Golden Ticket or Silver Ticket attack to succeed, an attacker must first gain access to the network, before carrying out the forged ticket attack.[4] Once inside the network however, both Golden Ticket and Silver Ticket attacks are extremely effective for establishing persistence within that network, since they allow for continuous use of their respective ticket, so long as the lifetime and validity remain in tact.

3 Golden Tickets

3.1 Fundamentals

As noted by Melnyk et al. (2023), the Golden Ticket attack is, at its core, based on falsification of the TGT.[5] Importantly, this does **not** imply that a TGT is generated and sent by the KDC and then received and altered by the client – rather, the client itself creates the TGT from scratch. Thus, in a Golden Ticket attack, the initial two steps from the standard Kerberos procedure are completely cut off. Figure 2 illustrates this fact; the client no longer has any exchanges with the AS in its quest to get access to a service.

[3] https://blog.quest.com/what-is-krbtgt-and-why-should-you-change-the-password/
[4] Melnyk: 755
[5] Melnyk: 752

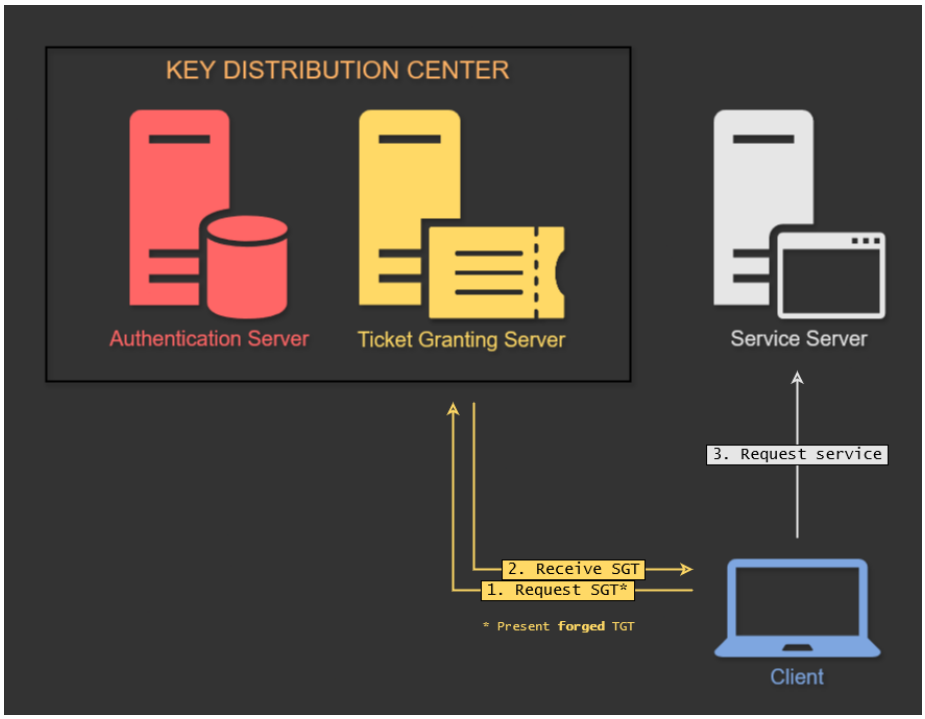


Figure 2: Golden Ticket attack procedure

In essence, Golden Tickets equate to forged TGTs. However, despite the forgery, the validity of a Golden Ticket remains perfectly in tact – it is, ultimately, encrypted and signed by a fully trusted entity in a network. In most Active Directory environments, this trusted entity takes the form of the domain Kerberos account (KRBTGT).[6] The fact that the TGT is encrypted by the KRBTGT password hash and can be decrypted by any TGS in the domain proves it is "valid".[7]

3.2 Detection

As noted by Soria-Machado et al. (2016), because a legitimate TGT and Golden Ticket are often indistinguishable, there is no universal rule to detect the presence of a Golden Ticket.[8] Even so, there exist ways in which to do so, but they often require that certain measures have been put in place ahead of time, and that an attacker does not actively attempt to circumvent these measures (or: does not prevent these measures from being effective).

[6] Metcalf 2015
[7] Metcalf 2015
[8] Soria-Machado 2016: 2

3.2.1 Requests

One way to detect a Golden Ticket is through network traffic analysis, by correlating AS requests with TGS requests. Recall from this paper's initial description of the Kerberos protocol, that AS requests always precede TGS requests in the Kerberos authentication process. However, in a typical Golden Ticket attack, there is no communication between the client and the AS; the client forges the TGT itself and effectively skips communication with the AS.[9]

Therefore, if the network analysis reveals that a particular user has sent a TGS request without any immediately preceding AS request, it could indicate that the account is compromised and utilized by an attacker. This is plausible even if their presented TGT was accepted and they received the service ticket; this is, after all, the whole point of the Golden Ticket – it is effectively a valid TGT.

However, an attacker that understands how Kerberos and Golden Tickets work will likely take necessary steps to elude this form of detection. Specifically, the attacker can make sure to always send a (strictly superfluous) request to the AS before sending a request to the TGS. The attacker can here exploit the fact that your average Key Distribution Center has no automated/integrated process for comparing TGTs issued to the user (by the AS) with TGTs presented by the user (to the TGS).[10] This allows the attacker to evade the traffic correlation detection method described above, but it may still be possible to detect an attacker through manual/separate comparison of TGTs, discussed next.

3.2.2 Responses

Logging of all TGTs issued by the AS will typically also facilitate detection of Golden Tickets. By comparing these tickets with TGTs presented by users, the presence of a Golden Ticket may be revealed if a user-presented TGT does not correlate to any of the issued TGTs. This would indicate that the user-presented ticket was never issued by the AS, and that the ticket instead was created by the user, which is precisely what we have seen in a typical Golden Ticket attack. (Consequently, given that the required log monitoring is in place, the presence of a Golden Ticket may be detected this way.)

However, it is important to note that an attacker may find ways to avoid this detection method as well. Melnyk et al. (2023) address the following scenario: First, a legitimate user authenticates on the network and obtains a TGT. Then, the attacker forges their own TGT and sets the username to that of the legitimate user.[11] From a non-attacker perspective, this makes it seem like the AS request and subsequent TGS request are directly linked and come from the same legitimate user, potentially allowing the attacker to elude detection.

Also, if the attacker has control over the AS, they can send a TGT back to

[9] Melnyk 2023: 753-754
[10] Metcalf 2015
[11] Melnyk 2023: 754

themselves with the same username as the one they create/forge and send to the TGS.

3.2.3 Other

The detection methods discussed so far do not assume that any steps have yet been taken to mitigate the attack. Interestingly, certain detections are only possible *after* taking specific actions. One such example is after performing a double reset of the KRBTGT password – a common mitigation strategy for Golden Ticket attacks.[12] This can open up for detection of a (likely non-active) Golden Ticket, through status messages appearing in, for instance, Windows Security Event logs.

Because Golden Ticket attacks generally affect Active Directory environments leveraging Kerberos, most machines on these networks will run some variant of a Windows operating system. This typically includes crucial components such as the Domain Controller (DC), where Windows Security Event logs may reveal information that can be tied to a Golden Ticket. Soria-Machado et al. (2016) suggest that, after resetting the KRBTGT password twice, the following status code may appear in these logs:

```
0x1F: Integrity check on decrypted field failed
```

The message of the status code implies that the Golden Ticket likely has seized functioning as a result of the double password reset. While knowledge of the mitigation strategy proving effective can be valuable, the awareness of an attacker being (or having been) present in the network can prove even more paramount. The downside to this detection method is that, as indicated, it requires an enforcement of the double reset, which can create cascading challenges in the infrastructure. Furthermore, the monitoring of this event is very limited in that there is no username or requested service linked to the TGT.[13]

3.3 Mitigation

A widely accepted method for both invalidating existing Golden Tickets and preventing the creation of new ones, is to change the KRBTGT password **twice** in quick succession, sometimes referred to as a 'double-tap'.[14] While changing this password **once** is an efficient strategy to invalidate future tickets created with the old hash, any existing Golden Tickets would remain valid until they expire. Contrastingly, changing the password a second time necessitates that all users within the domain re-authenticate.[15] This renders all existing tickets useless, effectively terminating any active Golden Tickets. In addition, it forces users to acquire new tickets using the updated KRBTGT password. Because

[12] Metcalf 2015
[13] Soria-Madhado 2016: 7
[14] Metcalf 2015
[15] Metcalf 2015

this updated password is unknown to the attacker, they will not be able to obtain a new Golden Ticket either (at least until a new password hash compromise).

4 Silver Tickets

4.1 Fundamentals

The Silver Ticket attack is similar to the Golden Ticket attack, but instead of cutting out only steps one and two from the standard authentication process, steps three and four are also omitted. This means there is not only no exchange with the AS, but also none with the TGS. In effect, the entire communication with the Key Distribution Center is fully cut off. This is illustrated in Figure 3, where the client directly approaches the SS hosting the desired service.

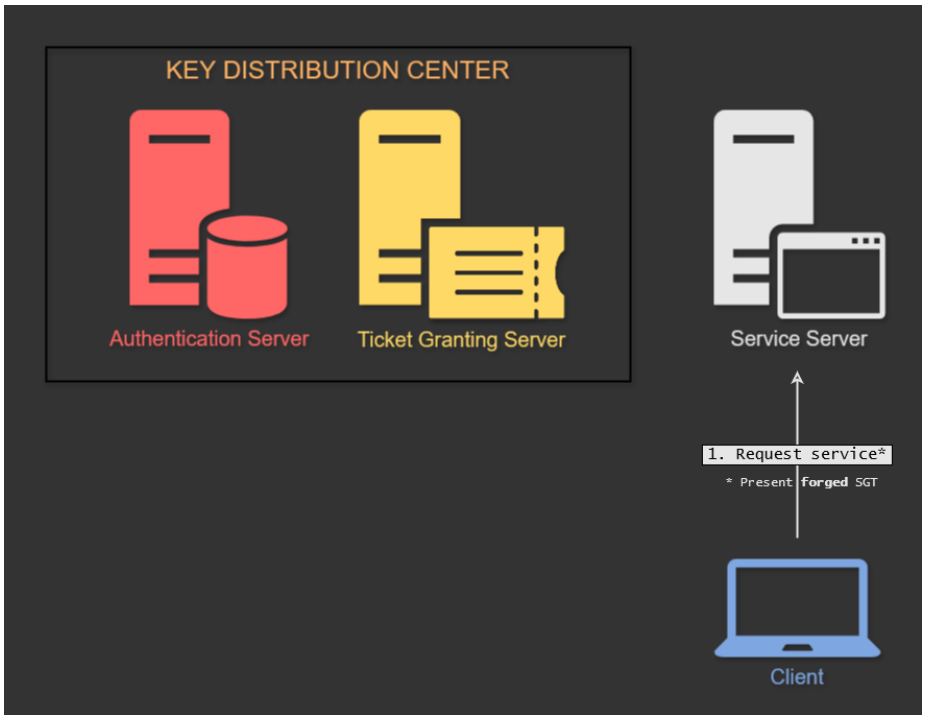


Figure 3: Silver Ticket attack procedure

Where Golden Tickets equate to forged TGTs, Silver Tickets correspond to forged SGTs, or service tickets. This naturally means that, for each different service the attacker wants to access, they would need to generate a separate Silver Ticket.

4.2 Detection

Existing research shows that detection of Silver Ticket attacks can be extremely difficult. Because this method circumvents involvement of both the Authentication Server and the Ticket Granting Server (and thus the KDC/DC as a whole), it is assumed to be even harder to detect than a Golden Ticket attack. In fact, experiments dedicated to revealing this type of attack sometimes conclude with no detection whatsoever.[16]

Nonetheless, it may be possible to detect Silver Tickets by examining various parameters/properties of Kerberos tickets – most notably their lifetime. Often, attackers will want to establish as much persistence as possible, and they may do so by maximizing the duration of their forged service ticket(s). In this situation, the unusually long lifetime of the ticket may reveal the attacker. However, this detection method relies on the attacker prioritizing persistence over stealth; an experienced and skilled attacker may purposefully set the duration to the default value on the domain, to avoid revealing their presence in the network.[17]

4.3 Mitigation

Because Silver Ticket attacks are inherently very difficult to detect, relevant literature often use a proactive approach – the goal is to prevent them from happening in the first place. As indicated, these attacks revolve around compromising service accounts, and so focus should be on maximizing their protection. Metcalf et al. (2015) recommend using long and complex passwords for these accounts, to increase the difficulty of account compromise.[18] This is not only an efficient technique, but it is also easily implemented. Mokhtar et al. (2022) refer to this as the best way to prevent Silver Ticket attacks.[19]

5 Discussion

5.1 Comparison

This section discusses some key differences between Golden and Silver tickets, largely based on what has been formalized in previous sections. While the two attacks share some notable similarities – such as both being based on ticket forging and post-exploitation – emphasis is put on how they differ from each other, to better understand their intricate distinctions and unique use cases.

5.1.1 Scope

In terms of scope, a Golden Ticket is more extensive than a Silver Ticket. Once a Golden Ticket is generated, it grants the attacker full access to the compromised

[16] Grippo 2022: 10
[17] Grippo 2022: 10
[18] Metcalf 2015: 24
[19] Mokhtar 2022: 11

domain, effectively allowing them to impersonate any user or service indefinitely until the ticket expires or is revoked. A Silver Ticket on the other hand, has limited scope and can only be used to access the specific service for which it was created.

5.1.2 Noise

Nonetheless, an advantage of Silver Tickets over Golden Tickets is that they are typically harder to detect and may provide attackers with more covert access to network resources. Since Silver Tickets are generated using legitimate service account credentials (albeit in the form of password hashes), they are less likely to raise suspicion compared to Golden Tickets, which are created using forged TGTs from the compromised KDC. Nonetheless, as we have seen, every time an attacker wants to access a new service, they would need to forge a separate Silver Ticket, which could potentially raise eyebrows during log examination.

5.1.3 Complexity

Grippo et al. (2022) state that, while the Golden Ticket attack is more powerful than the Silver Ticket attack, it is generally harder to perform. This is because an attacker would need to get their hands on information or data that is generally considered to be less attainable. For instance, in Active Directory, to perform a Golden Ticket attack, one would need the KRBTGT account's NTLM hash. This would involve compromising an account with elevated privileges (linked to the DC) in order to dump hashes of accounts within the domain.[20]

Silver Tickets on the other hand, are "merely" forged service tickets. A corresponding attack is based on obtaining a service account's hash, which is normally less complicated. To again use the Active Directory example, this means the attacker will only need to dump the NTLM hash of the service owner account instead of KRBTGT, and then they can generate the ticket valid for a service.[21]

In summary, the key difference between Golden Tickets and Silver Tickets lies in their scope and the level of access they provide. Golden Tickets grant full domain access, while Silver Tickets provide access to specific services within the domain. However, while Golden Tickets provide broader access and longer persistence within a network, Silver Tickets offer attackers a stealthier method for accessing specific resources without raising immediate red flags.

5.2 Alternatives

While this paper has provided an in-depth look at Golden and Silver tickets, it should be noted that these are not the only modern exploitation methods

[20] Grippo 2022: 8
[21] Scheepers 2022: 7

of Kerberos. Similar, yet conceptually different, attack techniques include Kerberoasting, pass-the-ticket, and credential stuffing.[22][23]

6 Conclusion

Golden Ticket and Silver Ticket attacks represent sophisticated methods that exploit vulnerabilities inherent in the Kerberos authentication process. Leveraging forged tickets, adversaries can masquerade as legitimate users, evade detection mechanisms, and gain unauthorized access to critical network resources. The repercussions of such breaches are profound, ranging from data exfiltration and privilege escalation to compromise of organizational infrastructures.

At its core, the Golden Ticket attack involves forging a ticket that can be used to access any services on the network, whereas the Silver Ticket attack involves forging a ticket that can be used to access a specific service on the network.[24]

In relevant literature, an interesting observation is that there is generally a larger focus on Golden Tickets than Silver Tickets. A natural explanation to this would have been if Golden Tickets were introduced prior to Silver Tickets, but as noted early on in this paper, the two concepts were presented around the same time (and place). Notably though, these talks largely focused on the former, which may well have contributed to a greater initial interest around Golden Tickets. In addition, the skewed focus may have been further realized by the greater capabilities and more noisy nature of Golden Tickets, making studies around both mitigation and detection more approachable and straightforward.

With respect to the various topics discussed in this paper, perhaps the greatest research gap discovered among existing literature has to do with reliable ways to detect Silver Ticket attacks. This is likely linked to the nature of the attack; it is highly stealthy and leaves very few traces of itself, making it all the more important that security researchers do not shun this problem. On the whole though, while it is the case that detection of Silver Tickets currently manifests a grand void in the defence against forged tickets, a fairly long line of highly recent academic research on the broader matter of Golden and Silver tickets, indicates that there is every chance this void will be covered in the near future.

Terminology

In this paper, the term Service Server (SS) corresponds to what is often coined Application Server (AS) in other research material. This is done to avoid confusion with the Authentication Server, which also abbreviates to AS.

Many sources use the abbreviation TGS for both the Ticket Granting Server and the ticket it provides. By the opinion of the author, this is a lazy 'solution',

[22] https://www.crowdstrike.com/cybersecurity-101/kerberoasting/
[23] https://www.varonis.com/blog/kerberos-authentication-explained
[24] Grippo 2022: 10

and a distinction is often needed. Therefore, in this paper, the ticket provided by the Ticket Granting Server is referred to as either a *Service Granting Ticket (SGT)* or simply a *service ticket*, the latter of which is most commonly used in existing research that distinguishes between the server and ticket in question.

Kerberized[25] environment is used some places, and its meaning is as simple as it sounds: It equates to an environment leveraging the Kerberos protocol.

Literature

Cervesato, I., Jaggard, A. D., Scedrov, A., Tsay, J.-K. & Walstad, C. (2008). Breaking and fixing public-key Kerberos. Advances in Computer Science - ASIAN 2006, 206(2), 402–424. https://doi.org/10.1016/j.ic.2007.05.005

Grippo, T. & Kholidy, H. A. (2022). Detecting Forged Kerberos Tickets in an Active Directory Environment. https://doi.org/10.48550/arXiv.2301.00044

Metcalf, S. (2015). Red vs. Blue: Modern Active Directory Attacks, Detection, and Protection Whitepaper. https://www.blackhat.com/docs/us-15/materials/us-15-Metcalf-Red-Vs-Blue-Modern-Active-Directory-Attacks-Detection-And-Protection-wp.pdf

Mokhtar, B. I., Jurcut, A. D., ElSayed, M. S. & Azer, M. A. (2022). Active Directory Attacks—Steps, Types, and Signatures. https://mdpi-res.com/electronics/electronics-11-02629/article_deploy/electronics-11-02629-v3.pdf

Motero, C. D., Higuera, J. R. B., Higuera, J. B., Montalvo, J. A. S. & Gomez, N. G. (2021). On Attacking Kerberos Authentication Protocol in Windows Active Directory Services: A Practical Survey. IEEE Access, 9, 109289–109319. https://doi.org/10.1109/ACCESS.2021.3101446

Scheepers, J. (2022). Keeping the attackers out: Golden tickets, silver tickets, and full domain recovery. WithSecure Consulting. https://www.withsecure.com/content/dam/with-secure/en/resources/withsecure-keeping-the-attackers-out-whitepaper-en.pdf

[25] https://www.varonis.com/blog/kerberos-authentication-explained